

Funções resumo (*Hash functions*)

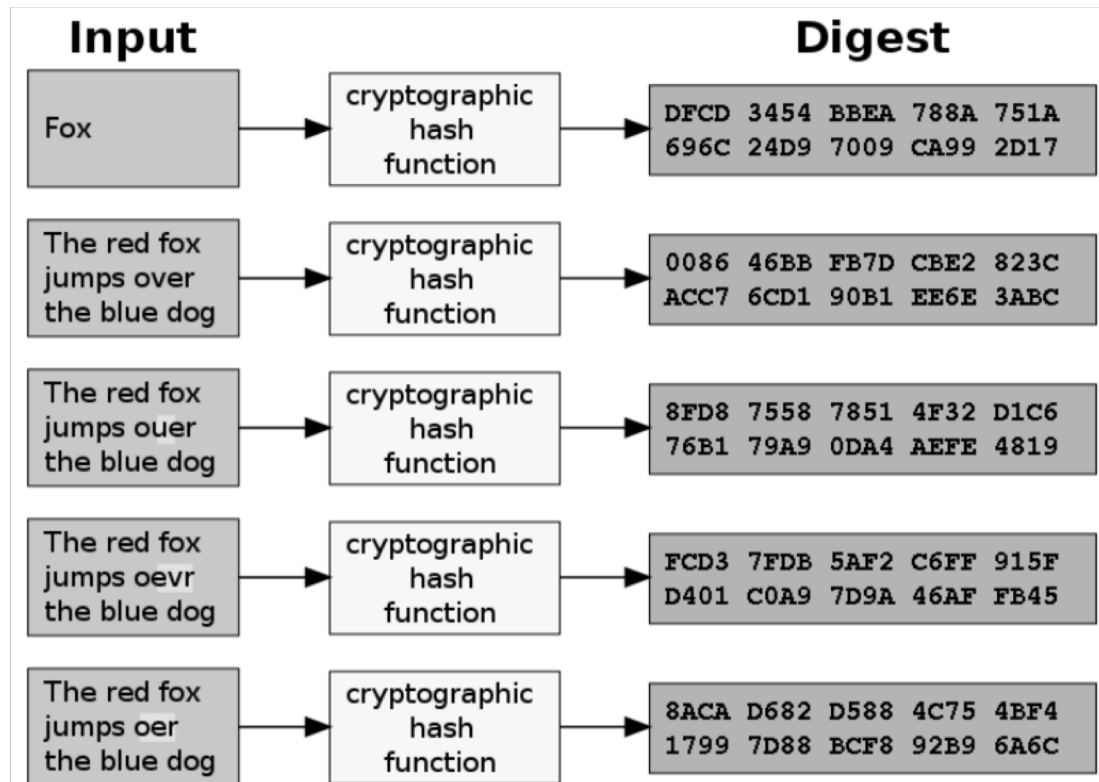
Prof. Avelino Francisco Zorzo
Escola Politécnica - PUCRS

Hash function

- Compress an arbitrary message into an output of fixed length (checksum)
 - Being used since 1950s
 - To facilitate detecting errors or data comparison

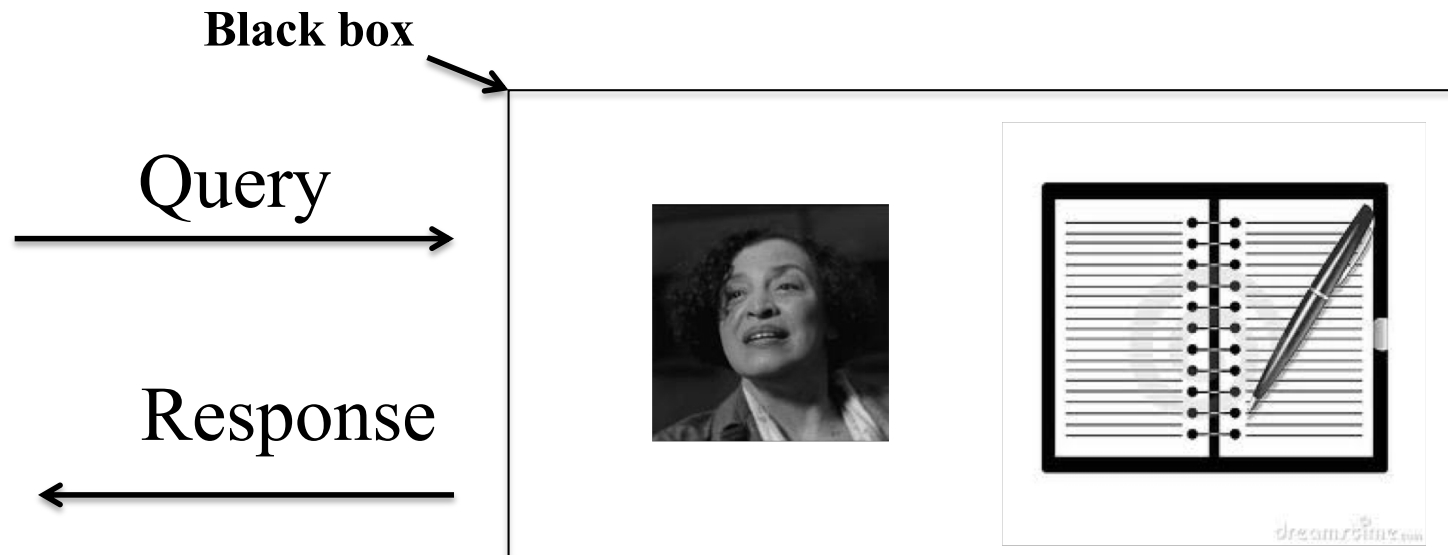
Cryptographic hash function

- Invented for digital signature
 - Provide assurance of data integrity
 - Avalanche effect



(Wikipedia)

Abstraction: random oracle model



If the query is **new**

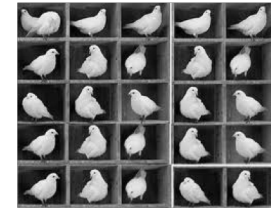
She gives you a fixed-length random string and marks a record on her book

Else

She looks up the book and gives you the same previous answer.

But ideal random oracle is impossible

- How to ensure that each output represents only one input message?
- That's theoretically impossible
 - The message space size is much larger than the size of the output space
- Practical solution
 - Ensure that it is computationally infeasible to find two messages with the same output



Security requirements of hash

■ Pre-image resistance

- Given $H(m)$, cannot find m

■ Second pre-image resistance

- Given $H(m_1)$, cannot find a different message m_2 , such that $H(m_1) = H(m_2)$

■ Collision resistance

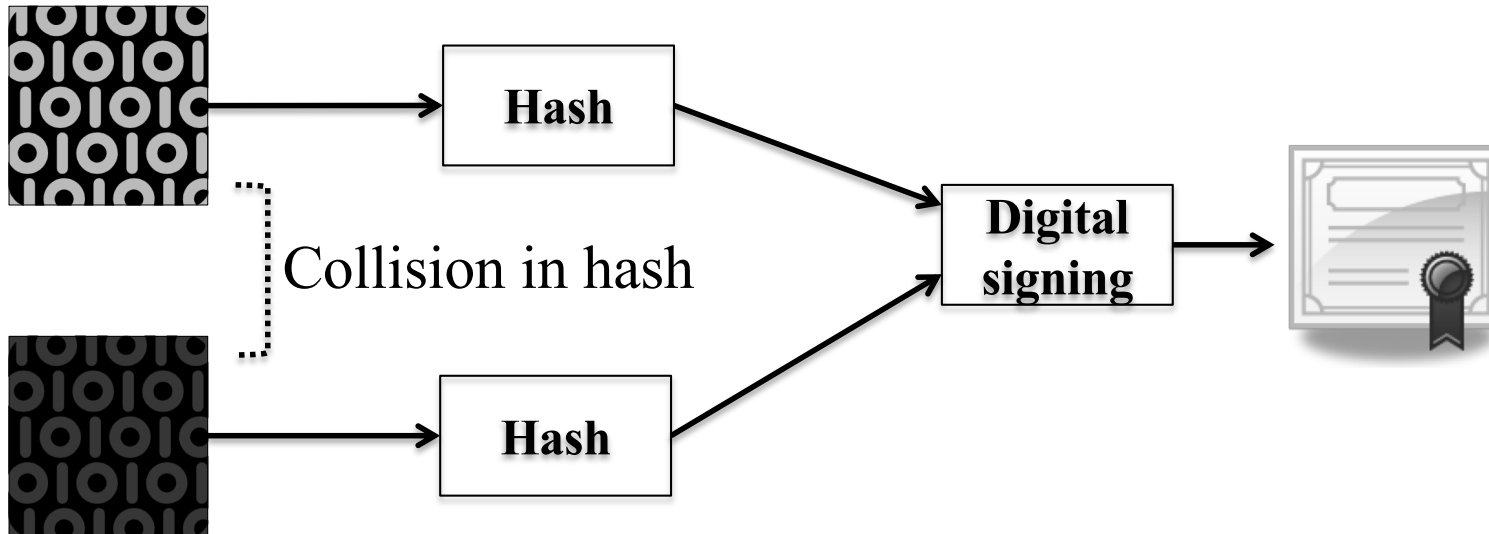
- Cannot find two different messages m_1 and m_2 , such that $H(m_1) = H(m_2)$

Hash family

- MD5 (1991) – (Message-Digest Algorithm 5)
 - 128-bit message digest
 - Broken by Wang Xiaoyun *et alli* in 2005
- NIST standard: Secure Hash Algorithm
- SHA-1 (1995) – Secure Hash Algorithm
 - 160-bit message digest
 - Insecure (2^{69} , Wang Xiaoyun *et alli* 2005)
- SHA-2 (2001)
 - SHA-256
 - SHA-512

Collision in hash is dangerous

Genuine program



Malware

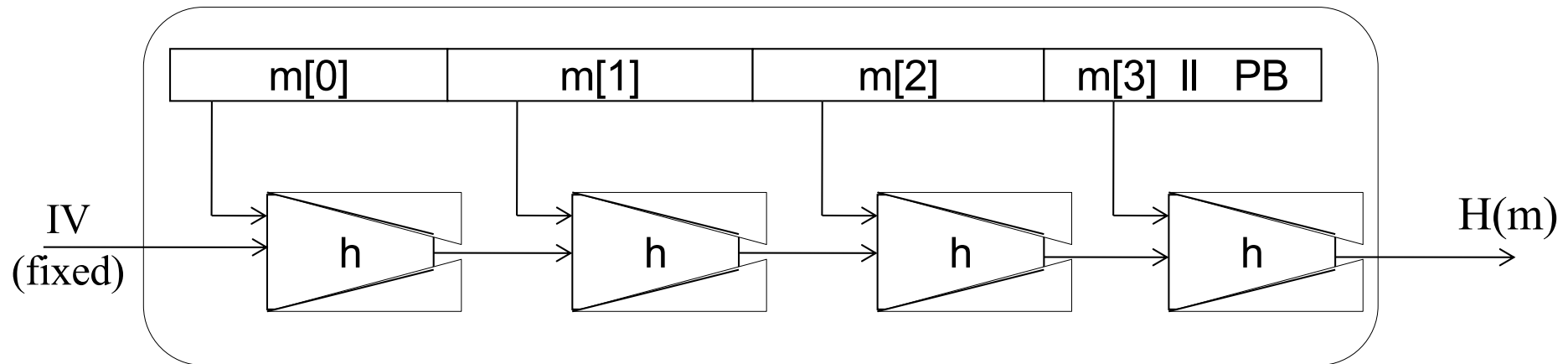
Real-world example: Flame malware

- Detected by Iran CERT in May 2012
- Advanced espionage malware
- It exploits MD5 collision
 - Microsoft Terminal Server Licensing Service certificate still uses MD5
 - Produced a counterfeit digital signature that appears to have originated from Microsoft

Hash function design basics

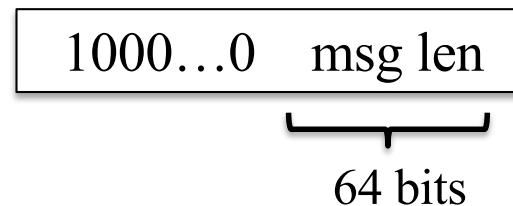
- A typical hash function involves three components in the design
 - Operation mode
 - Compression function structure
 - Confusion-diffusion operations

Merkle-Damgard construction



[Introduction to Cryptography – Dan Boneh]

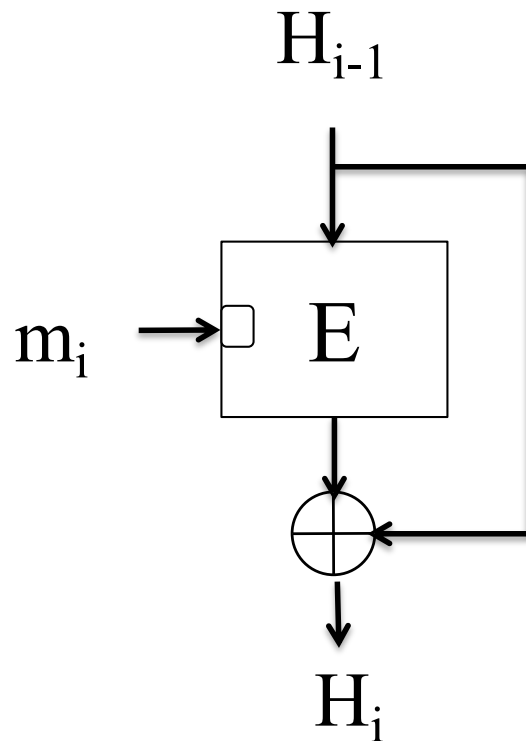
■ **PB: padding block**



■ **Theorem: If the compression is collision-resistant, then the hash function is collision resistant**

Compression functions

Davies-Meyer (used in MD5, SHA-1, SHA-2)

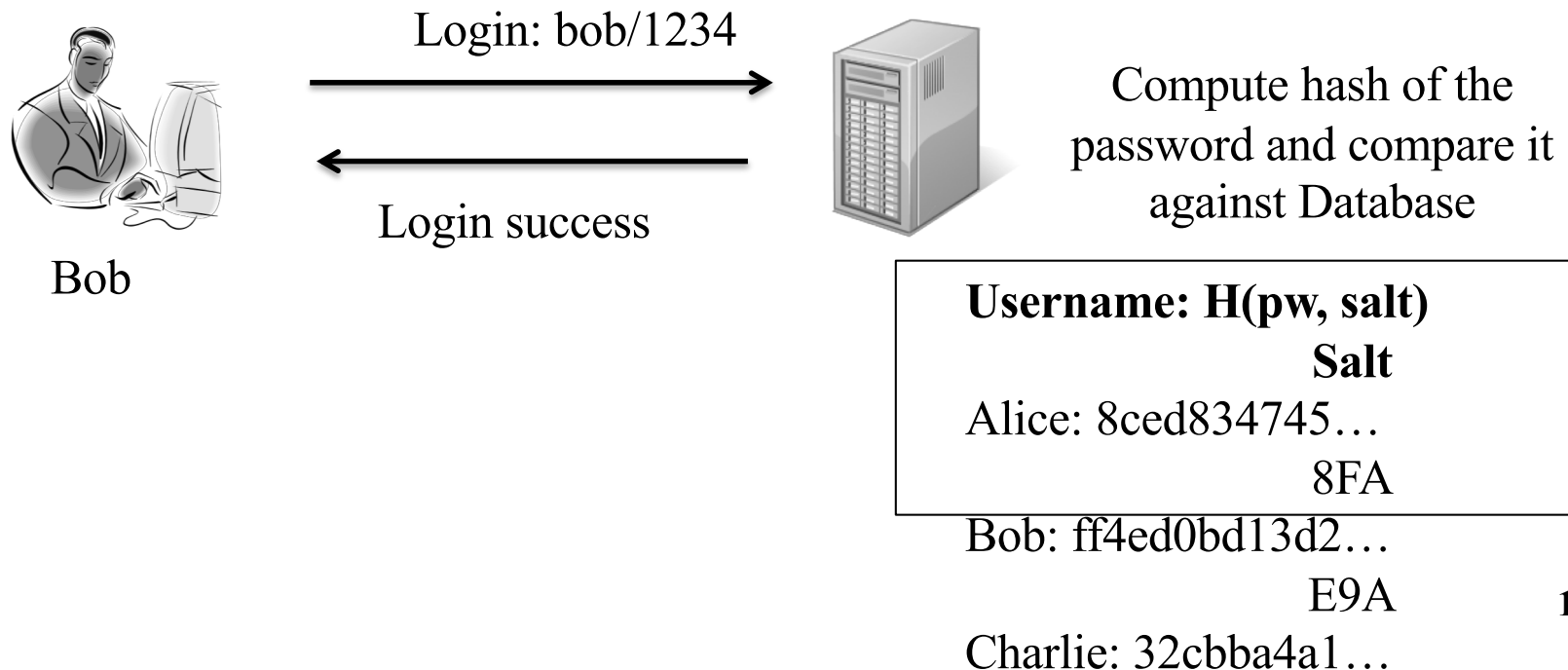
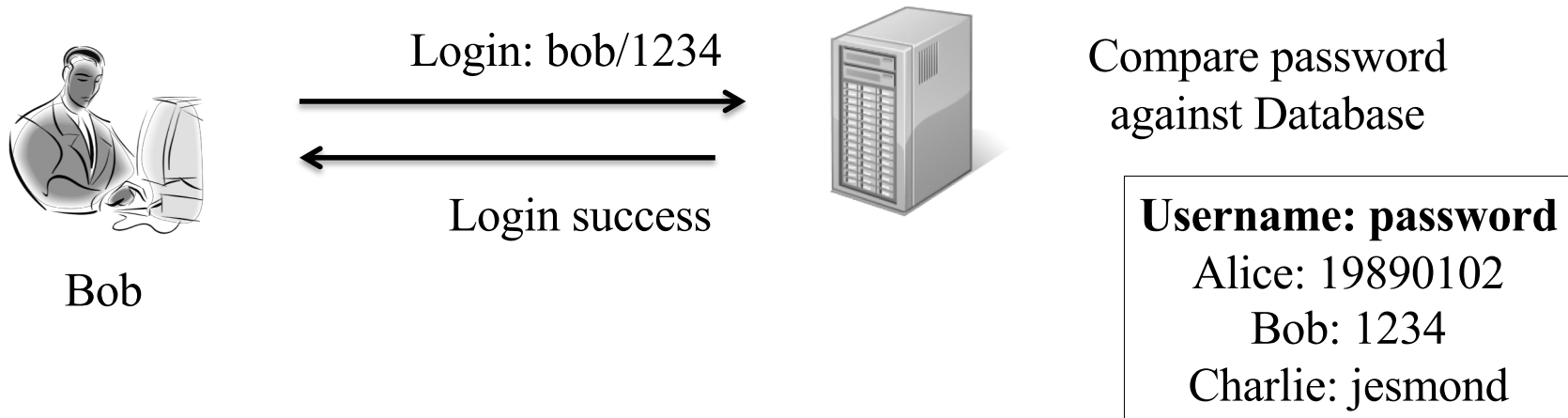


- E is a block cipher
- Use message as key
- $h(H, m) = E(m, H) \oplus H$
- Compression
 - Input size: key size + block size
 - Output size: block size

Applications of Hash

- Digital signature
- Data integrity (collision or pre-image resistance)
 - Example: Checksum for downloading software
- Random number generator
- Data privacy
 - Protect plain password
- Commitment scheme

Password authentication



Sadly, real-world security

- **2012-09-25: IEEE suffered a data breach**
 - 100,000 Plaintext passwords were leaked.
- **2012-07-12: Yahoo Voices database breached**
 - Half a million plaintext passwords leaked
- **2012-06-07: LinkedIn user database breached.**
 - 6.5 million Unsalted hashes dumped online.
- **2010-12-22: Gawker Media accounts hacked**
 - 1.3 million plaintext passwords were leaked

Caveat

- Hashing plaintext password with salt is only a best practice
 - It makes it difficult for the attacker to recover the password, but not impossible
- Dictionary attack
 - Given $H(\text{pw}, \text{salt})$ and salt
 - An attacker can exhaustively try out all passwords
 - The attack is feasible because passwords have low entropy